

Manual 08 - Ciclo de Vida de Risco de Fornecedores e Terceiros

CANDIDATO CONTROLADO PARA QA DE PUBLICACAO

Revisão da fonte controlada: c065e9ba7b7bbf37ff7c05de081a5864879e12ef | Idioma: pt-BR | limites de risco de fornecedores e de decisão humana mantidos.

Limite de asseguração: A governança de fornecedores baseada em risco reduz a incerteza, mas não elimina o risco de terceiros ou quartas partes. As evidências podem ser incompletas, desatualizadas, controladas externamente ou sujeitas a mudanças materiais. Responsáveis humanos mantêm as decisões de aprovação, exceção, risco residual, renovação e saída.

Caminhos de implementação

Manual 08 — Caminhos de Implementação do Ciclo de Vida de Risco de Fornecedores e Terceiros

Essencial

Use para organizações menores ou ecossistemas de fornecedores delimitados. Expectativas mínimas:

- inventário completo de fornecedores/serviços e responsável definido;
- classificação de criticidade/risco inerente;
- due diligence baseada em evidências e proporcional ao risco;
- decisão documentada de aprovar/condicionar/rejeitar;
- cláusulas contratuais obrigatórias de segurança/privacidade;
- controles de acesso e dados durante a integração;
- rota de notificação de incidentes/mudanças;
- atualização periódica de evidências e reavaliação;
- desligamento, revogação de acesso e evidência de devolução/exclusão de dados.

Estruturado

Use para múltiplos fornecedores críticos, dados regulados, dependência de nuvem/SaaS, terceirização material ou provedores de IA/modelos/API. Adicione:

- metodologia padronizada de classificação por níveis;
- requisitos de controles/evidências por nível;
- visibilidade de quartas partes/subprocessadores;
- validação independente de evidências e acompanhamento de exceções;
- revisão de resiliência/BCDR e risco de concentração;
- sinais de monitoramento contínuo e reavaliação acionada por eventos;
- planos formais de remediação e aceitação de risco;
- pontos de controle de renovação vinculados a questões não resolvidas.

Aprimorado

Use para infraestrutura crítica, terceirização em escala empresarial, IA de alto impacto, dependências sistêmicas de nuvem, dados regulados/de alto volume ou risco concentrado de fornecedores. Adicione:

- governança executiva de risco e cenários de concentração;
- arquitetura/fluxo de dados/linhagem de componentes;
- testes técnicos mais profundos ou asseguração independente quando justificado;
- análise de dependências materiais de quartas partes;
- proteções contratuais de auditoria/acesso/incidente/saída;
- exercícios conjuntos de incidentes e resiliência;

- validação de contingência/estratégia de saída;
- evidências contínuas e monitoramento de mudanças materiais.

Rota do ciclo de vida

Gráfico de memória do Manual 08 1

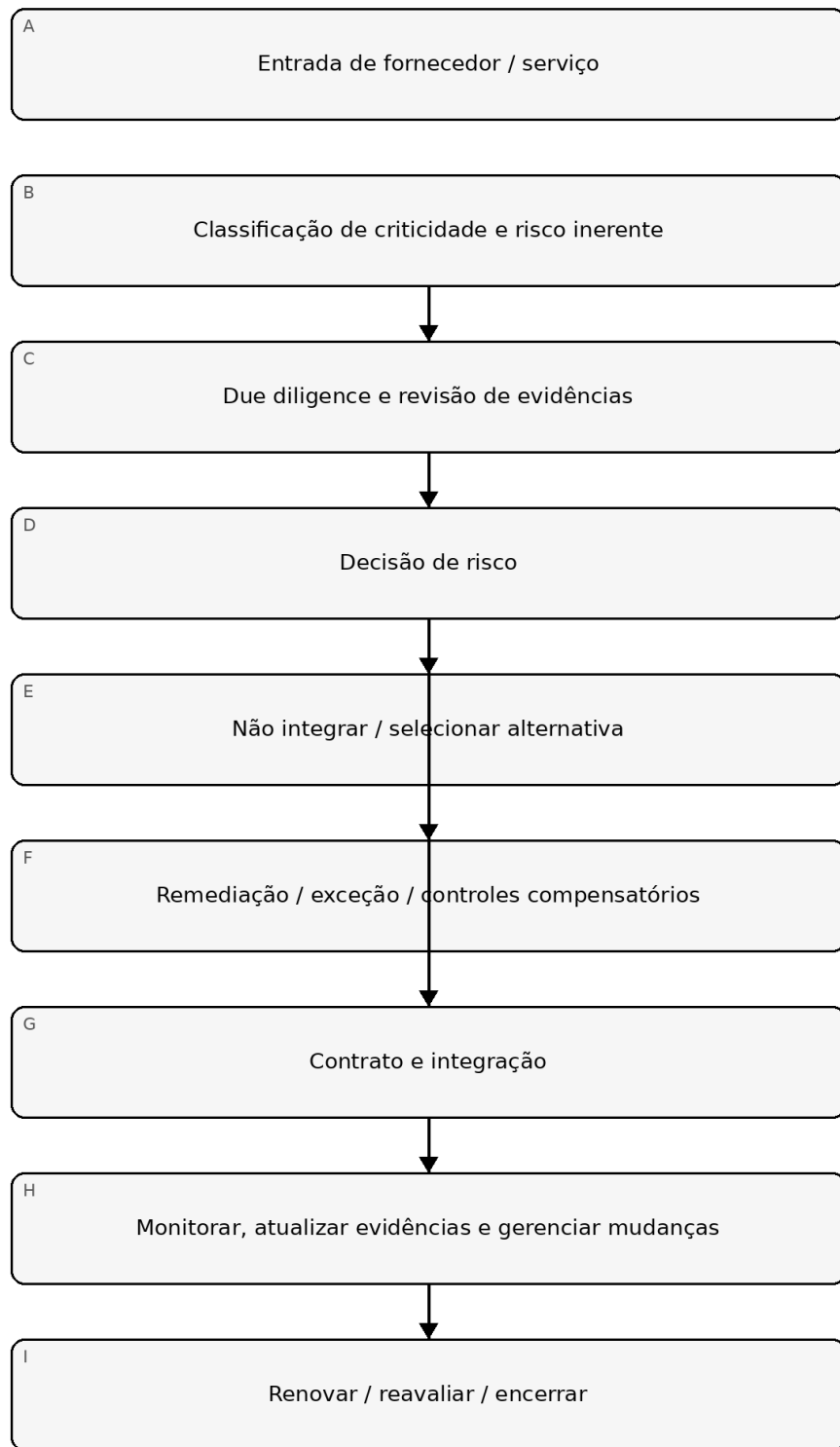


Figura 1. Gráfico de memória de implementação

Explicação acessível: Cada fornecedor começa com classificação e due diligence. As decisões podem rejeitar, aprovar condicionalmente ou aprovar o relacionamento. Fornecedores aprovados passam para operação monitorada e são reavaliados na renovação, em mudanças materiais ou no encerramento.

Cadeia de evidências e decisão

Gráfico de memória do Manual 08 2

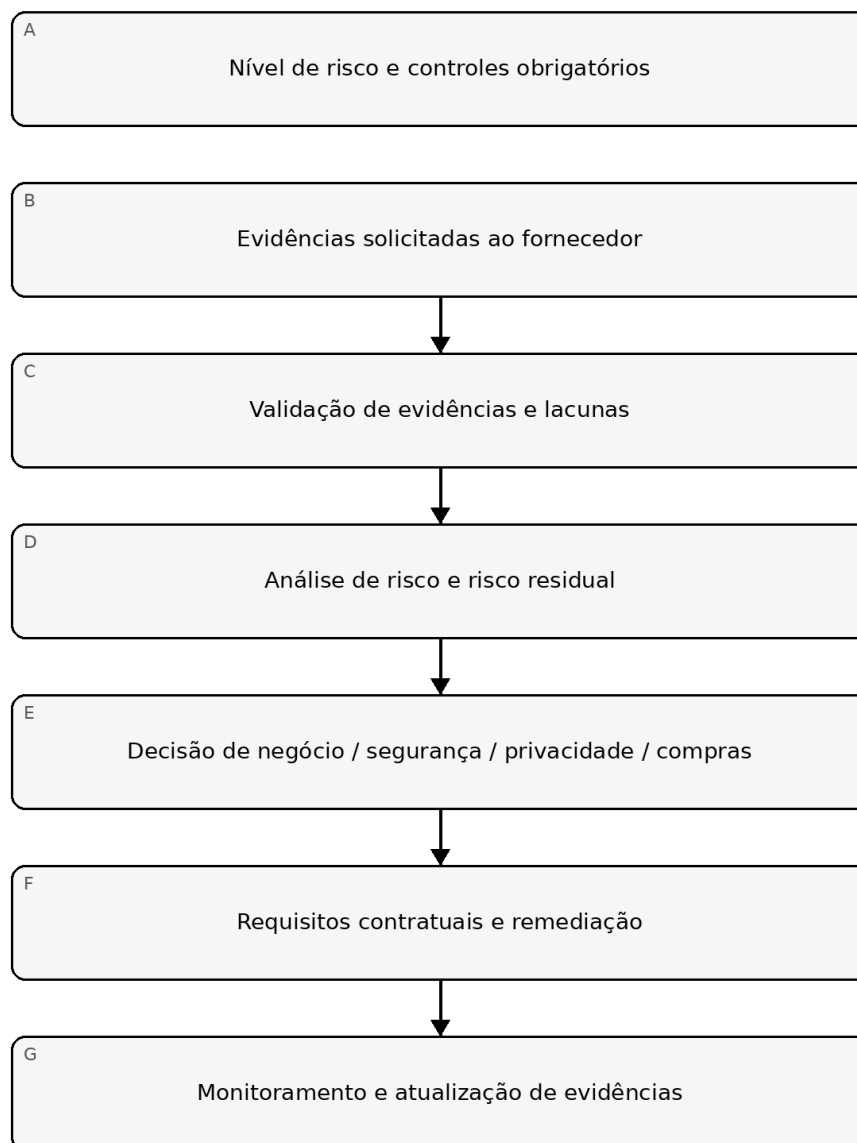


Figura 2. Gráfico de memória de implementação

Explicação acessível: As decisões sobre fornecedores se baseiam em controles obrigatórios, evidências verificadas, lacunas identificadas e risco residual. A decisão resultante orienta contratos, remediação e monitoramento contínuo, em vez de terminar no preenchimento de um questionário.

Cadeia de dependências de quartas partes e IA

Gráfico de memória do Manual 08 3

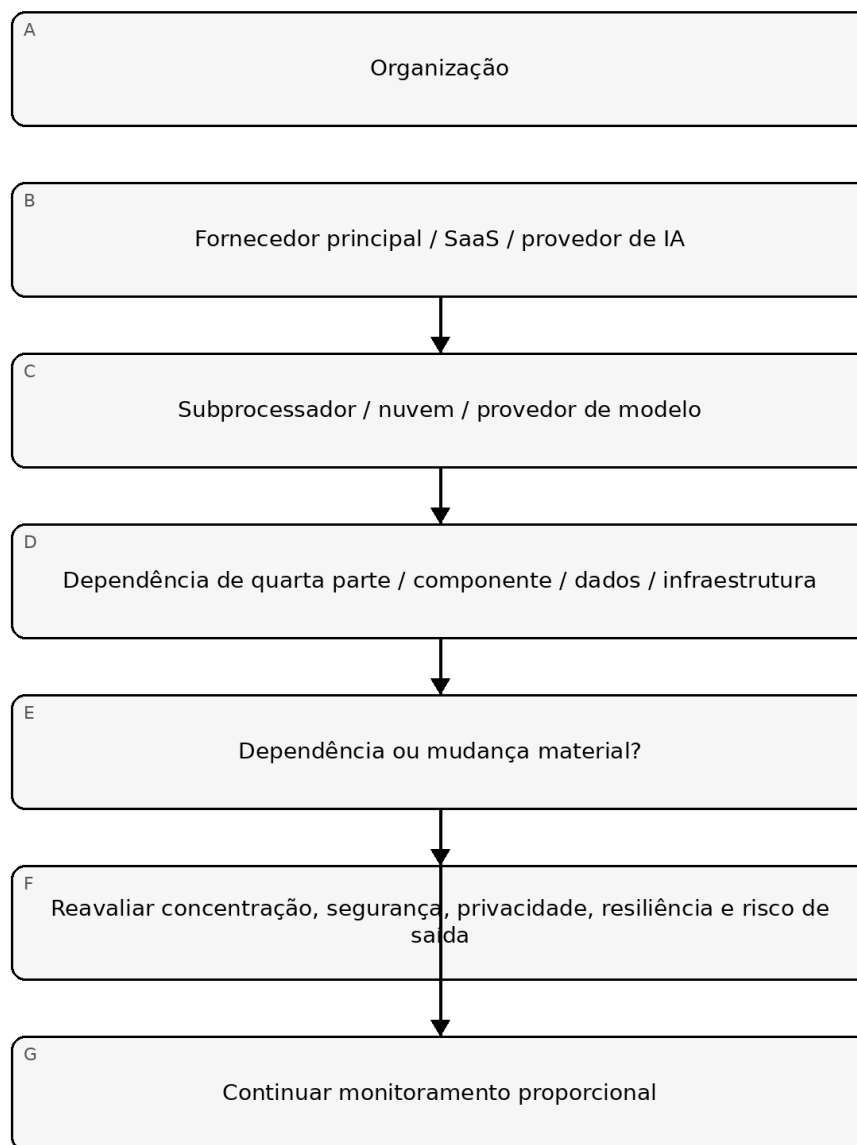


Figura 3. Gráfico de memória de implementação

Explicação acessível: O risco de fornecedores pode se estender além do fornecedor contratado para subprocessadores, provedores de nuvem/modelos e dependências de quartas partes. Dependências e mudanças materiais acionam reavaliação em vez de ficarem ocultas pelo contrato principal.

Controles obrigatórios do ciclo de vida

1. Inventário e responsabilidade por fornecedores/serviços.
2. Classificação de criticidade, risco inerente, dados, acesso, geografia, requisitos regulatórios e concentração.
3. Due diligence de segurança, privacidade, resiliência, IA, aspectos financeiros/operacionais e conformidade, conforme aplicável.
4. Validação de evidências—incluindo certificações, relatórios, arquitetura, políticas, evidências de testes, incidentes e remediação—não asseguração baseada apenas em questionários.

5. Decisão de risco e exceção/aceitação de risco documentada.
6. Controles contratuais: uso de dados, confidencialidade, segurança, notificação de incidentes, direitos de auditoria/evidência, subprocessadores, resiliência, uso de IA, retenção, exclusão e saída.
7. Integração de identidades, conectividade, fluxos de dados, chaves/segredos e responsabilidade.
8. Monitoramento contínuo, atualização de evidências e gatilhos de mudança material.
9. Gestão de incidentes, violações, interrupções de serviço, falhas de controles e remediação.
10. Pontos de controle de renovação e reavaliação.
11. Desligamento: revogação de acesso, devolução de ativos/chaves, devolução/exclusão de dados, retenção e evidências de transição/saída.

Limite de asseguração

A governança de fornecedores baseada em risco reduz a incerteza, mas não pode eliminar o risco de terceiros. O manual deve preservar lacunas conhecidas, dependência de evidências externas, limitações de quartas partes, risco residual e decisões humanas responsáveis.

Manual controlado de 32 capítulos

Capítulo 01 — Objetivo e ciclo de vida de TPRM

A gestão de riscos de terceiros deve governar todo o ciclo do relacionamento: entrada, classificação, due diligence, decisão de risco, contratação, onboarding, monitoramento, gestão de incidentes e mudanças, reavaliação e desligamento.

O processo deve ser aplicado proporcionalmente ao que o fornecedor pode acessar, influenciar, processar, hospedar, operar ou interromper.

Capítulo 02 — Inventário de fornecedores e responsáveis

Mantenha um inventário controlado de fornecedores, prestadores de serviços, subprocessadores, provedores de IA/modelos, provedores de dados, APIs, serviços de hospedagem e outras dependências externas relevantes.

Cada registro deve identificar responsável de negócio, serviço, dados tratados, dependências de sistemas, contrato, criticidade, geografia quando aplicável, exposição a quartas partes, data de renovação, nível de monitoramento e requisitos de saída.

Capítulo 03 — Criticidade e risco inerente

Criticidade pergunta o que acontece se o fornecedor falhar; risco inerente pergunta qual exposição existe antes de considerar controles. São relacionados, mas não idênticos.

Os fatores podem incluir acesso a dados sensíveis, conectividade privilegiada, acesso a produção, dependência operacional, concentração, substituíbilidade, impacto financeiro, exposição regulatória, autonomia de IA, dependência de modelos ou dados e consequências para continuidade de negócios.

Capítulo 04 — Planejamento da due diligence

A due diligence deve ser baseada em evidências e proporcional. O plano de revisão deve identificar as perguntas a responder, as evidências necessárias, os revisores e os limites de aceitação.

Possíveis evidências incluem políticas, relatórios independentes, certificações, informações de arquitetura, resultados de testes, histórico de incidentes, evidências de resiliência, documentação de privacidade, compromissos contratuais, informações financeiras e entrevistas direcionadas.

Um questionário isolado não constitui asseguração para um fornecedor material.

Capítulo 05 — Revisão de segurança, privacidade e resiliência

A revisão deve determinar se os controles do fornecedor são adequados ao serviço e à exposição. Segurança, privacidade e resiliência devem ser avaliadas como disciplinas conectadas, e não como questionários isolados.

A revisão deve abordar identidade, acesso, proteção de dados, logs, gestão de vulnerabilidades, resposta a incidentes, capacidade de recuperação, subcontratação, localização, retenção, exclusão e continuidade do serviço quando aplicável.

Capítulo 06 — Fornecedores de IA e dependências de modelos/componentes

A revisão de fornecedores de IA deve identificar provedores de modelos, inferência hospedada, serviços de fine-tuning, fornecedores de dados, serviços de segurança, fontes de recuperação, provedores de agentes/ferramentas e outros componentes de IA.

Questões-chave incluem uso de dados, comportamento de treinamento ou retenção, notificação de mudança de modelo/versão, limites de segurança, controles de conteúdo e abuso, disponibilidade do serviço, termos de propriedade intelectual, evidência de auditoria, notificação de incidentes e opções de saída.

Capítulo 07 — Decisão de risco e exceções

Todo resultado material de due diligence deve gerar uma decisão: aprovar, aprovar condicionalmente, exigir remediação, restringir escopo, adiar ou rejeitar.

As exceções devem registrar requisito não atendido, justificativa de negócio, controle compensatório, responsável, risco residual, aprovador, data de expiração e requisito de monitoramento. Exceções permanentes sem revisão periódica devem ser evitadas.

Capítulo 08 — Gate de onboarding com falha fechada

O onboarding deve falhar fechado quando a due diligence obrigatória estiver incompleta, faltarem evidências críticas, achados de alto risco não tiverem tratamento aprovado, termos contratuais obrigatórios estiverem pendentes ou faltar aprovação humana obrigatória.

Um fornecedor não deve ser apresentado como “aprovado” apenas porque o processo de compras foi concluído. Uma mudança material posterior — como novo subprocessador, modelo de serviço, uso de dados, componente de IA, região de hospedagem ou arquitetura de segurança — pode reabrir a revisão afetada.

Capítulo 09 — Qualidade da evidência

A evidência deve ser avaliada quanto à relevância, atualidade, escopo, independência e aplicabilidade ao serviço real. Um documento pode ser válido e ainda assim irrelevante se cobrir outro produto, ambiente, entidade ou período.

Capítulo 10 — Requisitos de controle contratual

Riscos materiais identificados durante a due diligence devem ser refletidos nos termos contratuais quando apropriado. Os temas podem incluir obrigações de segurança, privacidade/tratamento de dados, direitos de auditoria, notificação de incidentes, subcontratação, níveis de serviço, resiliência, notificação de mudanças, devolução/exclusão de dados e apoio à saída.

Capítulo 11 — Direito de auditoria e acesso à asseguuração

Cláusulas de direito de auditoria devem ser utilizáveis na prática. A organização deve entender se a asseguuração será fornecida por relatórios, certificações, pacotes de evidências, entrevistas, revisões direcionadas, trabalho presencial ou outros mecanismos.

Capítulo 12 — Subprocessadores e quartas partes

Subprocessadores e quartas partes materiais devem ser suficientemente visíveis para compreender concentração, tratamento de dados, dependência operacional e risco de mudança. O nível de visibilidade deve ser proporcional à exposição e à criticidade.

Capítulo 13 — Risco de concentração e dependência

A avaliação deve considerar se múltiplos processos críticos dependem de um único fornecedor, região, plataforma, provedor de modelo, serviço em nuvem ou dependência upstream. A concentração pode ficar oculta quando fornecedores diferentes compartilham o mesmo serviço subjacente.

Capítulo 14 — Evidência de resiliência e recuperação

Para serviços críticos, a due diligence deve examinar capacidade de recuperação, premissas de dependência, evidências de testes, objetivos de recuperação, processos de comunicação e se existe alternativa ou rota de saída viável.

Capítulo 15 — Notificação e coordenação de incidentes

Contratos e procedimentos operacionais devem estabelecer como incidentes materiais do fornecedor são comunicados, quais informações são esperadas, quem recebe a notificação e como contenção, investigação, recuperação e comunicações regulatórias ou com clientes serão coordenadas.

Capítulo 16 — Pacote de aprovação

O pacote de aprovação deve resumir escopo do serviço, criticidade, risco inerente, evidências de due diligence, achados materiais, tratamentos contratuais, exceções abertas, risco residual, nível de monitoramento, considerações de saída e aprovação humana.

A aprovação deve corresponder ao serviço e ao escopo efetivamente revisados.

Capítulo 17 — Controles de onboarding

O onboarding deve verificar se termos contratuais aprovados, limites de acesso, requisitos de tratamento de dados, contatos de segurança e incidentes, nível de monitoramento e responsabilidade pelo serviço estão implementados antes do uso em produção.

Capítulo 18 — Monitoramento contínuo

O monitoramento deve se concentrar em indicadores ligados a risco material: eventos de segurança, degradação do serviço, dificuldades financeiras, mudanças de controle societário, mudanças de conformidade, mudanças de subcontratados, mudanças de modelo ou plataforma, achados não resolvidos e obrigações contratuais.

Capítulo 19 — Atualização de evidências

As evidências devem ser renovadas de acordo com risco e validade. Relatórios independentes, certificações, políticas, evidências de testes, seguros, documentos de privacidade e artefatos de resiliência não devem continuar sendo considerados indefinidamente após ficarem desatualizados.

Capítulo 20 — Gestão de mudanças

Mudanças materiais do fornecedor devem acionar análise de impacto. Exemplos incluem novos subprocessadores, novas regiões de hospedagem, mudanças de arquitetura, mudanças no uso de dados, fusões, mudanças no modelo de serviço, mudanças de IA/modelo ou alterações em compromissos de segurança ou privacidade.

Capítulo 21 — Governança de achados e remediação

Achados devem ter responsáveis, severidade, ações, datas, evidências e escalonamento. Atrasos repetidos em remediações devem afetar o tratamento de risco e podem exigir restrições de serviço, controles adicionais, aceitação executiva ou planejamento de saída.

Capítulo 22 — Gestão de exceções

Exceções devem ter prazo definido e aprovação da autoridade adequada. O monitoramento deve verificar se controles compensatórios permanecem eficazes e se datas de expiração não são contornadas por renovação administrativa sem reavaliação.

Capítulo 23 — Reavaliação periódica

A reavaliação deve considerar escopo atual do serviço, criticidade, uso de dados, evidências de controles, incidentes, mudanças do fornecedor, desempenho, concentração, exposição a quartas partes, situação contratual e prontidão para saída.

Capítulo 24 — Decisão de renovação

A renovação deve ser uma decisão de risco, não um evento automático de compras. O registro de aprovação deve identificar achados não resolvidos, mudanças de exposição, evidências atuais, risco residual e se termos contratuais ou monitoramento precisam mudar.

Capítulo 25 — Revisão de desempenho e risco do serviço

O desempenho operacional deve ser avaliado junto com as evidências de controles. Falhas persistentes de serviço, compromissos não cumpridos, degradação de suporte ou incidentes repetidos podem alterar o risco residual mesmo quando documentos formais de asseguuração continuam válidos.

Capítulo 26 — Dependência financeira e estratégica

Quando material para a continuidade do serviço, a organização deve considerar viabilidade financeira, mudanças de propriedade, risco de aquisição, dependência estratégica e viabilidade de substituir o fornecedor.

Essas considerações devem ser tratadas proporcionalmente e com contribuição de especialistas apropriados.

Capítulo 27 — Devolução e exclusão de dados

O planejamento de saída deve definir quais dados, configurações, logs, artefatos, modelos, prompts ou outras informações devem ser devolvidos, transferidos, retidos ou excluídos. A conclusão deve ser evidenciada quando houver requisitos contratuais ou regulatórios.

Capítulo 28 — Encerramento de acessos

O desligamento deve revogar contas, credenciais, chaves de API, acesso à rede, acesso privilegiado, acesso de suporte, integrações, certificados e outras conectividades do fornecedor que não sejam mais necessárias.

Capítulo 29 — Transição e continuidade

Fornecedores críticos devem ter um plano de transição realista que considere serviços substitutos, migração de dados, dependências técnicas, transferência de conhecimento, prazos e controles provisórios.

Um plano de saída que não possa ser executado dentro das tolerâncias de negócio deve ser tratado como risco atual.

Capítulo 30 — Obrigações residuais

Após o término do serviço, algumas obrigações podem permanecer, incluindo confidencialidade, retenção de registros, exclusão de dados, cooperação em incidentes, suporte de auditoria, termos de propriedade intelectual ou retenções legais. Devem ser acompanhadas até a conclusão.

Capítulo 31 — Limitações da asseguuração TPRM

Um processo TPRM controlado reduz incerteza, mas não pode certificar um fornecedor como livre de risco. As conclusões devem identificar evidências, escopo, período, premissas e limitações das quais dependem.

Capítulo 32 — Limite de publicação do manual

Antes da publicação deste manual, devem estar completos a verificação de fontes, o mestre controlado em inglês, a revisão multidisciplinar, a revisão semântica es-419 e pt-BR, a revisão de gráficos/acessibilidade, QA documental e por página, proveniência, auditoria de segurança do repositório e a Aprovação Humana Final de Publicação.

Mudanças materiais após aprovação humana reabrem os gates afetados.